

Security Incident Report

Cloudora Security Operations | Template CLD-IR-TEMPLATE | Complete every section. If a section is empty, write why.

Report ID	CLD-IR-0001
Related ticket	CLD-0001 – Suspicious sign-in activity: Daniel.reeve@cloudora.io
Report title	Executive account takeover through password spraying with MFA persistence and BEC staging
Analyst	Ahmad Obeid – SOC Analyst, simulated Cloudora engagement
Date of report (UTC)	2026-08-10
Incident severity	P1
Status	Investigation complete – simulated containment actions documented
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Between 8 and 10 August 2026, an external attacker conducted a low-volume password-guessing campaign against 26 Cloudora employee accounts. The investigation confirmed that the attacker successfully accessed the accounts of Chief Executive Officer Daniel Reeve and employee Priya Nair, then accessed Daniel's mailbox and SharePoint Online through Priya's account. On Daniel's account, the attacker registered an unauthorised authentication device and created an email rule designed to hide finance and invoice-related messages, creating a significant risk of invoice fraud and reputational damage during an active enterprise deal. The investigation identified 24 additional targeted accounts and documented the required response actions, including session revocation, credential resets, removal of unauthorised access methods and mailbox rules, and blocking the attacker's infrastructure. No completed fraudulent payment or confirmed data theft was identified in the available logs, but the incident remains **P1** because two accounts were compromised and fraud preparation was observed.

2. Incident timeline

Time (UTC)	Source	Event	Evidence / notes
8 Aug, 00:00-05:00	CloudoraSignIn_CL	Password-spray campaign begins	44 failed attempts from three Lagos IPs across multiple Cloudora accounts.
9 Aug, 00:00–05:00	CloudoraSignIn_CL	Password-spray campaign continues	36 failed attempts from the same attacker infrastructure using the same low-and-slow pattern.
10 Aug, 00:35:48	CloudoraSignIn_CL	Failed sign-in against Daniel Reeve	102.89.44.17, Lagos, Nigeria; ResultType 50126; Windows 10 / Chrome 125.
10 Aug, 03:09:12	CloudoraSignIn_CL	Failed sign-in against Daniel Reeve	Same attacker IP and device footprint.
10 Aug, 03:10:41	CloudoraSignIn_CL	Further failed sign-in against Daniel Reeve	Second failure immediately before successful access.
10 Aug, 03:12:05	CloudoraSignIn_CL	Successful sign-in to Daniel Reeve's account	102.89.44.17, Lagos; Windows 10 / Chrome 125. Confirmed initial account access.

10 Aug, 03:14:30	CloudoraSignIn_CL	Daniel Reeve's mailbox accessed	Successful Outlook Web session from the attacker IP.
10 Aug, 03:18:44	CloudoraAudit_CL	Unauthorized authentication method registered	Attacker added an authenticator app named Pixel 6 to Daniel's account.
10 Aug, 03:26:02	CloudoraSignIn_CL	Azure Portal accessed through Daniel's account	Successful session from 102.89.44.17.
10 Aug, 03:31:09	CloudoraAudit_CL	Malicious inbox rule created	Rule RSS Subscriptions moved finance or invoice-related messages to RSS Feeds and marked them as read.
10 Aug, 03:44:55	CloudoraSignIn_CL	Failed sign-in against Priya Nair	102.89.45.101, Lagos; Windows 10 / Chrome 125.
10 Aug, 03:47:18	CloudoraSignIn_CL	Successful sign-in to Priya Nair's account	Same attacker IP and device fingerprint; second account confirmed compromised.
10 Aug, 03:52:40	CloudoraSignIn_CL	Priya Nair's SharePoint accessed	Successful SharePoint Online session from 102.89.45.101
10 Aug, 08:41:00	CloudoraSignIn_CL	Daniel Reeve signs in normally from London	203.0.113.11; macOS 14 / Safari 17. Supports the conclusion that the earlier Lagos session was unauthorized.
10 Aug, 08:55:00	Ticket CLD-0001	Suspicious sign-in escalated for investigation	Cloudora IT identified the impossible-travel alert involving the CEO account.

3. Findings

Finding 1 - Daniel Reeve's account was compromised from Lagos

daniel.reeve@cloudora.io successfully authenticated from 102.89.44.17 in Lagos at 03:12:05 UTC on 10 August 2026 using Windows 10 and Chrome 125. The login was preceded by failed attempts at 00:35:48, 03:09:12 and 03:10:41, then followed by Outlook Web and Azure Portal access. Daniel's normal baseline was almost entirely London-based, and he later signed in normally from London at 08:41 using macOS and Safari.

This combination of failed attempts, unfamiliar device, unusual location and same-day London activity confirms account takeover rather than legitimate travel.

Finding 2 - Initial access resulted from a three-night password-spray campaign

The three Lagos IP addresses generated 114 failed authentication attempts across 26 distinct Cloudora accounts between 8 and 10 August:

*102.89.44.17 — 48 failures across 23 accounts
102.89.45.101 — 38 failures across 20 accounts
102.89.44.23 — 28 failures across 18 accounts*

The attacker made only a small number of attempts against each account while targeting many different users, which is consistent with password spraying rather than brute-forcing one account. This matters because the attack was detectable on the first night, two days before the successful compromises.

Finding 3 - The attacker established persistence on Daniel's account

At 03:18:44 UTC, six minutes after the successful login, the audit log recorded User registered security info for Daniel's account from 102.89.44.17. The details showed that an authenticator application named Pixel 6 was added.

This created persistence because the attacker could continue authenticating even after a password reset. Credential reset alone would therefore not fully contain the account.

Finding 4 - The attacker created an inbox rule consistent with BEC staging

At 03:31:09 UTC, the attacker created an inbox rule named RSS Subscriptions on Daniel's mailbox. The rule moved messages from finance@cloudora.io, or messages containing invoice, into the RSS Feeds folder and marked them as read.

This behavior is consistent with Business Email Compromise staging because it hides finance-related messages from the mailbox owner and could support invoice fraud. No fraudulent outgoing message or payment was observed in the available logs, so fraud preparation is confirmed, but completed fraud is not.

Finding 5 — Priya Nair was the second compromised account

priya.nair@cloudora.io was targeted by the same Lagos infrastructure across all three nights. A failed sign-in from 102.89.45.101 occurred at **03:44:55 UTC**, followed by a successful authentication at **03:47:18 UTC** and SharePoint Online access at **03:52:40 UTC**. Priya's baseline contained 33 normal London sign-ins and no prior legitimate foreign activity. No persistence events were found for her account in the available audit logs, but absence of persistence evidence does not prove the account was clean.

Finding 6 — Omar Farah's Dubai activity was legitimate travel

omar.farah@cloudora.io recorded 12 successful Dubai sign-ins across 8–10 August. These occurred during daytime hours, succeeded without preceding failures and consistently used his normal iOS 17 and Mobile Safari device fingerprint.

The Lagos events associated with Omar were failed password-spray attempts only. Omar is therefore cleared as a false positive for the Dubai activity, but he remains one of the 24 targeted-but-not-breached accounts requiring a precautionary password reset.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
IPv4 address	102.89.44.17	8 Aug 2026, approximately 00:00	Lagos password-spray source. Used to compromise Daniel Reeve, access Outlook Web and Azure Portal, register an MFA device, and create the malicious inbox rule.
IPv4 address	102.89.44.23	8 Aug 2026, approximately 00:00	Lagos password-spray source. Generated 28 failed sign-ins across 18 accounts.
IPv4 address	102.89.45.101	8 Aug 2026, approximately 00:00	Lagos password-spray source. Used to compromise Priya Nair and access SharePoint Online.
Device fingerprint	Windows 10 / Chrome 125	8 Aug 2026	Consistent device and browser fingerprint associated with the 102.89.x.x attacker activity.
MFA device name	Pixel 6 authenticator application	10 Aug 2026, 03:18:44	Unauthorized authentication method registered on Daniel Reeve's account to establish persistence.
Inbox rule name	RSS Subscriptions	10 Aug 2026, 03:31:09	Malicious rule created on Daniel's mailbox to hide messages from finance or containing the word invoice.

5. MITRE ATT&CK; mapping

Tactic	Technique ID	Technique name	Evidenced by
--------	--------------	----------------	--------------

Credential Access	T1110.003	Brute force: Password Spraying	Finding 2 — 114 failed sign-ins across 26 accounts from three Lagos IP addresses over three nights.
Initial Access	T1078	Valid Accounts	Findings 1 and 5 — successful attacker sign-ins to Daniel Reeve and Priya Nair using compromised credentials.
Persistence	T1098.005	Account Manipulation: Device Registration	Finding 3 — unauthorized Pixel 6 authenticator application registered on Daniel's account.
Defense Evasion	T1564.008	Hide Artifacts: Email Hiding Rules	Finding 4 — inbox rule RSS Subscriptions created to hide finance and invoice-related messages.

6. Scope

Accounts confirmed compromised

Two Cloudora accounts were confirmed compromised through successful sign-ins from the attacker-controlled 102.89.x.x infrastructure:

daniel.reeve@cloudora.io — successfully accessed at 03:12:05 UTC on 10 August 2026 from 102.89.44.17, followed by Outlook Web and Azure Portal access, unauthorized MFA registration, and creation of a malicious inbox rule.
priya.nair@cloudora.io — successfully accessed at 03:47:18 UTC on 10 August 2026 from 102.89.45.101, followed by SharePoint Online access at 03:52:40 UTC.

Both accounts require full containment, credential reset, session revocation, MFA review, and post-compromise activity review.

Accounts targeted but not breached

The password-spray campaign targeted 26 distinct accounts. After excluding the two confirmed compromises, 24 accounts received failed attempts only:

alba.vega@cloudora.io
amelia.frost@cloudora.io
aria.reid@cloudora.io
cole.burke@cloudora.io
dina.said@cloudora.io
emma.hayes@cloudora.io
ethan.wells@cloudora.io
freya.lynn@cloudora.io
gwen.muir@cloudora.io
isla.grant@cloudora.io
joel.kerr@cloudora.io
jude.ross@cloudora.io
kian.patel@cloudora.io
leah.stone@cloudora.io
lena.voss@cloudora.io
liam.doyle@cloudora.io
mira.shah@cloudora.io
nina.cole@cloudora.io
omar.farah@cloudora.io
rhys.owen@cloudora.io
ruth.dean@cloudora.io
ryan.boyd@cloudora.io
seth.lane@cloudora.io

sofia.marino@cloudora.io

No successful attacker sign-ins were identified for these accounts in the available logs. All 24 should receive precautionary password resets and further authentication review because they were directly targeted by the spray campaign.

Accounts investigated and cleared (false positives)

omar.farah@cloudora.io — Dubai sign-ins were assessed as legitimate travel because they occurred during daytime hours, succeeded without prior failures, and used Omar's usual iOS 17 / Mobile Safari device fingerprint across multiple days.

Omar was cleared as a compromise false positive, but he remains in the targeted-but-not-breached group because the Lagos password-spray infrastructure attempted to access his account six times.

Overall Incident Scope

- 26 accounts targeted
- 2 accounts confirmed compromised
- 24 accounts targeted but not breached
- 1 investigated travel anomaly cleared as benign
- 3 attacker IP addresses identified
- 1 unauthorised MFA method
- 1 malicious inbox rule
- SharePoint access observed on the second victim

7. Actions taken

Because this investigation used historical training data rather than a live Cloudora tenant, no response actions were executed. The table below records the recommended response sequence, responsible roles, and verification methods.

Time (UTC)	Action	Performed by	Verified how
Not executed — training scenario	Revoke all active sessions and refresh tokens for daniel.reeve@cloudora.io and priya.nair@cloudora.io	Proposed for Cloudora identity administrator	Confirm both users are forced to authenticate again and no existing attacker sessions remain active.
Not executed — training scenario	Reset the passwords for both confirmed compromised accounts	Proposed for Cloudora identity administrator	Confirm the previous credentials no longer work and review subsequent authentication events.
Not executed — training scenario	Remove the unauthorised Pixel 6 authenticator application from Daniel Reeve's account	Proposed for Cloudora identity administrator	Review Daniel's registered authentication methods and confirm only authorised methods remain.
Not executed — training scenario	Review Priya Nair's authentication methods for unauthorised registrations	Proposed for Cloudora identity administrator	Confirm no unknown MFA methods or devices are registered.
Not executed — training scenario	Delete the malicious inbox rule named RSS Subscriptions from Daniel Reeve's mailbox	Proposed for Cloudora messaging administrator	Review the mailbox-rule list and confirm the rule no longer exists.
Not executed — training scenario	Audit both compromised mailboxes for additional forwarding rules, inbox rules, delegates, and suspicious messages	Proposed for Cloudora messaging administrator and SOC	Confirm no other attacker-created mailbox configuration or fraudulent outbound messages are present.
Not executed — training scenario	Block 102.89.44.17, 102.89.44.23, and 102.89.45.101 using Conditional Access or named locations	Proposed for Cloudora security administrator	Re-run attacker-IP queries and confirm no successful activity occurs after the block.

Not executed — training scenario	Force precautionary password resets for the 24 targeted-but-not-breached accounts	Proposed for Cloudora identity administrator	Confirm password resets are completed and review each account for successful attacker authentication.
Not executed — training scenario	Review Priya Nair's SharePoint activity following the 03:47 compromise	Proposed for Cloudora SOC and SharePoint administrator	Identify files viewed, downloaded, modified, shared, or deleted during the attacker session.
Not executed — training scenario	Re-run the CEO timeline and compromise-scope queries after containment	Proposed for Cloudora SOC	Confirm no further successful sign-ins from 102.89.x.x infrastructure and no additional compromised users.

8. Recommendations

- Revoke sessions and reset credentials for both compromised accounts immediately.**
Daniel Reeve and Priya Nair should be forced to reauthenticate using newly issued credentials after all active sessions and refresh tokens are revoked.
- Require multi-factor authentication for all Cloudora accounts.**
The two compromises succeeded through password guessing. Strong multi-factor authentication would reduce the likelihood that a stolen or guessed password alone results in account access.
- Review and restrict authentication-method registration.**
New MFA methods, particularly on executive and privileged accounts, should generate high-priority alerts and require additional verification or administrator approval.
- Monitor mailbox rules and forwarding changes.**
New inbox rules, external forwarding addresses, delegate changes and finance-related message-routing rules should trigger alerts, especially on executive and finance accounts.
- Deploy the password-spray detection rule developed during this investigation.**
The rule should identify one IP address generating failed authentication attempts across at least 10 distinct accounts within six hours. This activity was detectable on the first attack night, approximately two days before the successful compromises.
- Create a second rule for failed attempts followed by successful authentication.**
Successful access from an IP previously associated with password spraying should generate a higher-severity incident because it may indicate confirmed account compromise.
- Force precautionary password resets for the 24 targeted-but-not-breached accounts.**
These accounts received direct password-spray attempts. Their authentication histories should also be reviewed for successful access from unfamiliar infrastructure.
- Review Conditional Access policies.**
Cloudora should require step-up authentication or block access from countries where it has no business activity, while maintaining an exception and verification process for legitimate travel.
- Perform a deeper review of post-compromise activity.**
Daniel's mailbox and Priya's SharePoint activity should be examined for file access, downloads, external sharing, mailbox forwarding, suspicious messages and other evidence of data exposure.
- Brief the finance and executive teams on Business Email Compromise risk.**
Any request to change payment details, bank accounts or supplier information should be verified through a separate trusted communication channel.
- Disable legacy authentication where possible.**
Authentication methods that do not support modern security controls should be disabled to reduce opportunities for account takeover.
- Establish monitoring for low-and-slow identity attacks.**
Longer detection windows should be used alongside short-term rules so attackers cannot avoid detection simply by spreading attempts over several nights.

9. Lessons learned

The investigation showed that a basic password-spray detection rule could have identified the attack on 8 August, approximately two days before Daniel Reeve and Priya Nair were compromised. Monitoring only individual account failures would have been insufficient because the attacker deliberately spread a small number of attempts across many users.

Reviewing both sign-in and audit logs was essential. The sign-in logs confirmed the account takeovers, while the audit logs revealed the unauthorised authentication device and malicious inbox rule. Without the audit evidence, a password reset alone might have left the attacker's persistence mechanisms in place.

Scoping beyond the original CEO alert identified Priya Nair as a second victim and showed that 24 additional accounts had been targeted. This demonstrated that an investigation should not stop after confirming the first compromised user.

The comparison between Daniel Reeve and Omar Farah also demonstrated that location alone is not sufficient to determine whether activity is malicious. Timing, authentication failures, device fingerprints, normal account behavior and activity across multiple days were required to distinguish legitimate travel from account takeover.

The available telemetry also had limitations. No persistence was observed for Priya Nair, but this should be recorded as an absence of evidence rather than proof that no persistence existed. Additional endpoint, email, SharePoint and identity telemetry would be required to determine the complete impact.

Future investigations should document findings as they are discovered, use automated detection for password spraying and new authentication methods, and verify containment by re-running the original investigation queries after response actions are completed.